Assessment 01: Security foundations

Task A: Secure a student account

A1 & A2: Risk Assessment Table

Risk	Asset	CIA impact	Control	Limitation
Using same weak password across multiple accounts.	Her email account and learning portal data	Confidentiality: Hacker can guess that short password easily compared to long one, they can gain unauthorized access to read her private emails and grades	Implement a Password Manager to generate and store long, different(unique) passwords for each site.	Master password is the limitation of the Password manager, if a hacker gets that password, they just get access to all of her other passwords stored in that.
Approving the unexpected sign-in prompts	Her online accounts (email and learning portal)	Confidentiality and Integrity: Hacker can gain unauthorized to her online accounts, which can result in data breach, and her private information, or the ability to send assignments in name.	Implement Number Matching MFA (using authenticator app)	Users can still be targeted and tricked through advanced phishing sites (Intelligent Adversary-in-the-Middle attacks) that steal the matching number
Postponing device and software updates are big risks.	Her laptop and apps on the laptops	Availability, Confidentiality and Integrity: System gets more vulnerable when it's out-of-date, security of the system can breach easily which can results in system malfunction.	Make your device and software updated (check updates regularly, and enable auto updates for OS and all installed apps)	If she updates her system just after an update release can sometimes cause system failure.

Keeps her only project copy on one laptop	Her Projects and data on the laptop.	Availability: If laptop is stolen or broken the only copy of the project is gone, A hacker could also delete it.	She can use cloud storage to store her projects and important data as backup.	Cloud Storage: costs for the storage, sometimes there (cloud service provider's) server can go down
A friend sometimes uses that laptop under Mira's signed-in account	Her data and project Ideas and projects, some private and confidential data can be leaked	Confidentiality, and Integrity: As letting her friend to use her laptop while her account is signed – in can result in data breach, some modification in confidential docs and her logs can be stolen.	She should log out from her login first and then provide her friend after creating a guest user login to use the laptop, ensure that she logs out of her account before giving the laptop to her friend.	As it is the only laptop the malware can still be injected as in guest logins also and that will get the data when Mira will login her account.

A2: Control Priorities

My first priority for Mira is to implement a Password Manager to fix the root vulnerability of her weak, reused passwords.

Second, she must enable Number Matching MFA to stop immediate unauthorized access, acting as a safety net even if her password is breached.

Third Priority is Cloud Backups to secure her physical data and ensure her school project is safe if her laptop is ever compromised or hacked.

A3: Authentication vs. Authorization

Authentication: This is the process of proving who you are. Like Mira proving who she is to the system. For example, she authenticates by entering her student username, password, and MFA code on the learning portal's login screen.

Authorization: This is where we determine, now that she has logged in, she has proven who she is, what do we give them access to? For example, the learning portal authorizes her to view her own grades and submit her projects, but she is not authorized to alter her grades or access another student's account.

Task B: Analyze a suspicious message

B1: Warning Signs Analysis

Suspicious Phrase	Why it needs scrutiny
Scholarship Desk **awards@campus-awards.example** and help@personal-awards.example	The official college domain is **campus.example** The sender is using fake, spoofed domains, and the reply-to address does not even match its own sender's domain.
Subject: FINAL WARNING - scholarship expires in 20 minutes Open https://campus-awards.example/verify immediately	This creates a false sense of extreme urgency. Phishing attack relies on artificial time pressure to force victims, so that they gets trapped in nets easily.
Open https://campus-awards.example/verify immediately and enter your college password and OTP to avoid cancellation	College IT departments or accounts (finance related) offices never ask you to hand over your raw password and OTP codes to claim an award.
Do not contact the college office because their system is unavailable	This sender is trying to stop the student from verifying the email through officials. Organizations encourage verification, whereas scammers invent excuses to prevent you from checking their announcements or claims.
Reply with a photo of your identity card to speed up payment	Asking for a photo of an official ID card over an unverified email is a massive red flag, they can misuse the students ID.

B2: Verification Process

Safe Verification process: To verify safely, the student should open a new web browser tab and type the official campus.example website, then login to their student portal and check for official notifications (announcements). They can also call the accounts office or registrar office of the college to verify.

HTTPS or a familiar display name alone would not prove the message is genuine: Because anyone can type “Scholarship Desk” as their name in the email, and scammers can easily get the SSL certificates (the tech that creates the “HTTPS” padlock) for their fake websites. HTTPS just means that connection is encrypted, it does not verify about the person on the other end and their honesty.

B3: Response Plan

1. **Immediate containment**: The student must immediately log into their account through official portal and change their password. He should also log out of all devices to kick the hacker out. He should also verify if are there any active sessions.
2. **Official reporting**: The student must promptly contact the college IT Helpdesk, campus security, and the accounts office to report the compromised account so administrators can monitor for unauthorized activity.
3. **Checks**: The student should check their email settings to ensure the hacker did not set up the automatic forwarding rules to steal the future emails. The student should also verify that their backup recovery email and phone number were not altered.

B4: Missing Evidence

From the text message alone, we cannot establish the true origin of the sender because the **From** address can be easily spoofed. To verify the actual sender, an analyst would need the full email routing header to check the originating IP address.

Task C: Triage a sign-in alert

C1: Incident Timeline

Time	Observed Event	Interpretation
09:00-09:01	A successful password entry and MFA approval occurred from IP 192.0.2.10 (the usual classroom egress).	The user (student 07) logged into their account normally while in class.
10:14-10:16	Two failed password attempts were followed by a successful password entry from a new IP (198.51.100.23). The user stated that he did not attempt to sign in during this time.	An unauthorized actor from a different location attempted to guess the password and succeeded on the third try.
10:17-10:18	An MFA request from the new IP was denied at 10:17, followed by an approved request at 10:18. The student stated they approved it to stop the repeated requests	The attacker used an MFA fatigue tactic. The student initially resisted but ultimately approved the fraudulent request out of annoyance
10:20	A session was successfully created for student07 from the new IP address (198.51.100.23)	The attacker successfully bypassed both the password and MFA controls, gaining full unauthorized access to the account.

C2: Explanation of Failed Passwords

Explanation: An unauthorized attacker manually attempted to guess the student's password-or tried to manually type a password they stole from a phishing site-and made two typos getting it right on the third try.

Alternative Explanation: An automated credential stuffing script was running against the college's login portal, trying various breached passwords from old databases until it finally found the correct one for student07.

Alternative Explanation: An automated credential stuffing script was running against the college's login portal, trying various breached password from old databases until it finally found the correct one for student07.

Two Additional Checks:

1. **Check User-Agent logs**: Review the specific browser details (User-Agent string) for those login attempts to see if they came from a normal web browser or an automated tool/ script.
2. **Check for broad targeting:** Search the system logs to see if that same source IP (198.51.100.23) was attempting to log into other student accounts at the same time, which would strongly indicate an automated attack.

C3: Prioritized Response Actions

1. **Protect the Account (Containment):** The IT team must immediately terminate the active unauthorized session created at 10:20, force a mandatory password reset for student07, and temporarily lock the account to halt the attacker's access.
2. **Preserve Evidence:** Securely export and back up all system logs, including the authentication attempts, session tokens, and any activity tied to both student07 and the IP address 198.51.100.23, ensuring the data is isolated before it gets overwritten.
3. **Investigate post-compromise Activity:** Review the account's activity logs from 10:20 onwards to determine if the attacker accessed sensitive data, sent internal phishing emails, or set up malicious forwarding rules.

C4: Incident Summary

On 18 October 2026, an attacker successfully compromised student07's account from an IP 198.51.100.23 by bypassing password controls and utilizing an MFA fatigue tactic, which led the user to approve a fraudulent prompt at 10:18. While evidence clearly shows an unauthorized session was created at 10:20, there remains uncertainty regarding whether the initial password Attempts were manual or automated, and what data the attacker accessed post-compromise. Because of the active breach, this incident is a high priority. The immediate next actions are to terminated the active session, reset credentials, and investigate post-login activity.

Task D: Review an AI security answer

D1: AI Output Corrections

Unsafe Claim / Action from AI	Correction and Evidence
The email is safe because it uses HTTPS	HTTPS only encrypts data in transit. It does not guarantee the sender is safe, as attackers can easily obtain SSL certificates for malicious phishing infrastructure
The sign-in logs prove that the person using 198.51.100.23 stole the password	An IP address identifies a network routing point, not a specific human being. Logs only prove the IP was used to authenticate, not the identity of the person at the keyboard
MFA prevents every account compromise	MFA can be bypassed. Evidence from Task C shows attackers can defeat it using "MFA fatigue" or prompt bombing, tricking the user into approving the request
Delete the suspicious logs…	Deleting logs is a critical security violation. Incident response protocols mandate that logs must be preserved as forensic evidence to investigate the breach.
...and send the student's password to support so they can test it	Passwords must never be shared, transmitted in plaintext, or used by IT staff. Support teams must force a password reset or use dedicated test accounts to troubleshoot

D2: Improved AI Prompt

Act as a cybersecurity analyst. Please review the provided synthetic sign-in logs and email headers to explain what happened during this incident. You must strictly separate verified facts (what the logs explicitly show) from assumptions (what might have happened). Do not request, process, or output any real student data, passwords, or secrets. Finally, clearly state any areas of uncertainty where the provided evidence does not give a complete picture of the attacker's actions.

D3: Corrected Security Advice

While a website using HTTPS encrypts your connection, it does not guarantee the site or email is safe, as malicious actors frequently use valid SSL certificates for phishing campaigns. Furthermore, an IP address in a sign-in log only identifies the network used to authenticate; it cannot definitively prove the physical identity of the attacker. Although Multi-Factor Authentication (MFA) is a critical security layer, it is not foolproof and can be defeated through social engineering or MFA fatigue attacks. Therefore, continuous user vigilance remains essential. In the event of a suspected compromise, you must immediately secure the account by forcing a password reset and terminating active sessions. Never share passwords with IT support or transmit them in plaintext. Finally, it is crucial to preserve all system logs and avoid deleting any evidence, as these records are vital for forensic investigation

D4: AI-Use Declaration and References

- **AI-Use Declaration & Acknowledgement:** Google Gemini was utilized as an interactive mentor and sounding board to discuss cybersecurity concepts, structure the analysis, and refine the clarity of the final report.
- **Reference Note 1:** CISA - Secure Our World (https://www.cisa.gov/secure-our-world) - This guidance supports the corrected advice regarding the risks of phishing even when HTTPS is present, as well as best practices for MFA and password protection.
- **Reference Note 2:** NIST - Generative AI Profile, AI 600-1 (https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf) - This document supports the necessity of evaluating the AI output for confabulations, reinforcing why human judgment and verification are required for the AI's unsafe claims.